most critical web app risks, so it's important to be aware of them and to avoid introducing them into your apps.

TIP OWASP publishes the list online, with descriptions of each attack and how to prevent those attacks. There's a cheat sheet for staying safe here: https://cheatsheetseries.owasp.org.

In this section I'll provide an overview of some of the other most common vulnerabilities and how to avoid them in your apps.

29.4.1 Detecting and avoiding open redirect attacks

A common OWASP vulnerability is due to open redirect attacks. An *open redirect attack* occurs when a user clicks a link to an otherwise-safe app and ends up being redirected to a malicious website, such as one that serves malware. The safe app contains no direct links to the malicious website, so how does this happen?

Open redirect attacks occur where the next page is passed as a parameter to an endpoint. The most common example is when you're logging in to an app. Typically, apps remember the page a user is on before redirecting them to a login page by passing the current page as a `returnUrl` query string parameter. After the user logs in, the app redirects the user to the `returnUrl` to carry on where they left off.

Imagine a user is browsing an e-commerce site. They click Buy for a product and are redirected to the login page. The product page they were on is passed as the `returnUrl`, so after they log in, they're redirected to the product page instead of being dumped back to the home screen.

An open redirect attack takes advantage of this common pattern, as shown in figure 29.9. A malicious attacker creates a login URL where the